

MailFlow

Security & Access Control Document

1. Purpose

This document defines the security architecture, authentication, authorization, and access control mechanisms implemented in MailFlow to protect user data, lead information, campaigns, and application resources.

2. Security Objectives

Ensure confidentiality, integrity, and availability of user data while preventing unauthorized access and protecting against common web application attacks.

3. Authentication

Users authenticate using email/password or OAuth (future). Passwords are hashed using bcrypt. JWT access tokens secure API requests and refresh tokens maintain user sessions securely.

4. Authorization

Role-Based Access Control (RBAC) is implemented. MVP supports a single user role. Future versions will include Admin, Manager, and Team Member roles with different permissions.

5. Access Control

Every authenticated user can access only their own leads, campaigns, templates, analytics, and uploaded files. All database queries are filtered using the authenticated user's identifier.

6. Data Security

Sensitive data is encrypted during transmission using HTTPS/TLS. Secrets and API keys are stored in environment variables and never exposed to the frontend.

7. Password Policy

Passwords are never stored in plain text. Minimum password requirements and secure password reset mechanisms are enforced.

8. API Security

All protected APIs require JWT authentication. Rate limiting, request validation, Helmet security headers, CORS configuration, and input sanitization are enabled.

9. Email Security

SPF, DKIM and DMARC should be configured for production domains. Email sending is processed through trusted providers such as Resend or SendGrid.

10. File Upload Security

Only supported file formats (.xlsx and .csv) are accepted. Uploaded files are validated before processing to prevent malicious uploads.

11. Logging & Monitoring

Authentication attempts, email jobs, API failures and critical security events are logged for auditing and troubleshooting.

12. Backup & Recovery

Database backups are scheduled regularly. Application configuration is version-controlled and recovery procedures are documented.

13. Future Enhancements

Multi-factor authentication (MFA), OAuth providers, audit logs, IP restrictions, encryption at rest, SSO and fine-grained RBAC.

Security Controls Summary

Area	Implementation
Authentication	JWT + bcrypt
Authorization	Role-Based Access Control
Transport Security	HTTPS / TLS
Password Storage	bcrypt Hashing
API Protection	Helmet, CORS, Validation, Rate Limiting
Secrets	Environment Variables
Email Security	SPF, DKIM, DMARC
File Validation	.xlsx / .csv Validation